

Healthcare IT Fundamentals - Lecture 2

Regulatory Frameworks & Compliance (Simple Notes)

Big Picture

Healthcare technology is not just about software and databases.

Every healthcare system must follow strict laws and regulations that:

- Protect patient privacy
 - Secure health data
 - Ensure data sharing
 - Improve healthcare quality
 - Prevent misuse of information
-

1. HIPAA - The Most Important Healthcare Law

What is HIPAA?

HIPAA

HIPAA = Health Insurance Portability and Accountability Act

Its main goal is:

Protect Patient Health Information (PHI)

Think of HIPAA as:

The GDPR of healthcare in the United States.

2. What is PHI?

PHI = Protected Health Information

Any information that can identify a patient.

Examples:

- Name
 - Address
 - Phone number
 - Medical records
 - Lab reports
 - Diagnoses
 - Insurance details
-

3. Major HIPAA Rules

A. Privacy Rule

Controls:

- Who can access patient data
- When data can be shared
- Patient rights regarding their records

Example

Allowed:

Doctor accesses patient's record for treatment.

Not Allowed:

Receptionist checks celebrity medical records out of curiosity.

B. Security Rule

Focuses on:

Protecting Electronic Health Information (ePHI)

ePHI

Electronic Protected Health Information

Examples:

- EHR data
 - Medical images
 - Digital prescriptions
 - Cloud-stored patient records
-

4. Who Must Follow HIPAA?

Covered Entities

Organizations directly involved in healthcare.

Examples:

- Hospitals
 - Clinics
 - Doctors
 - Insurance companies
-

Business Associates

Third parties handling healthcare data.

Examples:

- Cloud providers
- IT support companies
- Billing companies
- Software vendors

Even if you are a software engineer working for a healthcare vendor, HIPAA still applies.

5. Minimum Necessary Principle

One of HIPAA's most important concepts.

Rule:

People should only access the information needed for their job.

Example

Doctor:

- Can view full medical record

Billing Staff:

- Can view billing information

Housekeeping Staff:

- Should not access patient records
-

Think like Role-Based Access Control (RBAC) in software engineering.

6. HIPAA Safeguards

HIPAA requires 3 layers of protection.

A. Administrative Safeguards

Policies and procedures.

Examples:

- Employee training
 - Security policies
 - Incident response plans
-

B. Physical Safeguards

Protect physical systems.

Examples:

- Locked server rooms
 - Badge access
 - Security cameras
-

C. Technical Safeguards

Technology controls.

Examples:

- Encryption
 - Passwords
 - Multi-factor authentication
 - Audit logs
-

7. Promoting Interoperability Program

Previously called:

Meaningful Use

Created after the HITECH Act.

Goal

Not just:

✗ Install EHR

But:

✓ Actually use EHR effectively

✓ Share health data

✓ Improve patient care

Example

Bad:

```
Hospital installs EHR.  
Nobody uses it properly.
```

Good:

```
Doctors use EHR daily.  
Patients access records online.  
Data is exchanged with other hospitals.
```

8. Interoperability

What is Interoperability?

Different healthcare systems communicating with each other.

Example:

Hospital A sends patient records to Hospital B.

Hospital B can understand and use them immediately.

Software Engineer Analogy

Like APIs between microservices.

Without interoperability:

```
Service A cannot talk to Service B
```

With interoperability:

Service A ↔ Service B

Same idea in healthcare.

9. Patients Own Their Data

Modern regulations emphasize:

Patient data belongs to the patient.

Patients should be able to:

- View records online
 - Download records
 - Share records
 - Use healthcare apps
-

10. Quality Reporting

Healthcare organizations must regularly report quality metrics.

These reports affect revenue.

eCQM

Electronic Clinical Quality Measures

Data automatically extracted from EHR systems.

Examples

- Hospital readmission rates
- Infection rates
- Diabetes management

- Blood pressure control
-

Why Important?

Government and insurers use this data to determine:

- Incentives
 - Ratings
 - Reimbursements
-

11. Documentation Matters

A healthcare organization may provide excellent care.

But if data isn't documented correctly:

The system cannot report it.

Result:

- Lower quality scores
 - Financial penalties
-

Software Analogy

Imagine:

```
user_name = ""
```

Even though the user exists.

If data isn't stored correctly:

Reports show incorrect results.

Healthcare faces the same issue.

12. Consequences of HIPAA Violations

Very serious.

Financial Penalties

Organizations may face:

- Large fines
 - Government investigations
-

Reputation Damage

Patients lose trust.

This often costs more than the actual fine.

Lawsuits

Patients may sue if their data is exposed.

Federal Oversight

Government may monitor the organization for years.

13. Employee Violations

HIPAA violations are not limited to organizations.

Individuals can also be punished.

Example

Employee checks:

- Neighbor's records

- Ex-partner's records
- Celebrity records

Just out of curiosity.

Result:

- Immediate termination
 - Possible legal action
 - Criminal penalties
-

14. Role of Administrative Staff

Security is everyone's responsibility.

Not just doctors and IT teams.

Responsibilities include:

- Following access rules
 - Protecting passwords
 - Locking screens
 - Properly disposing documents
 - Reporting incidents
-

15. Physical Security

Simple mistakes can cause breaches.

Examples:

- ✗ Leaving patient records on desk
 - ✗ Throwing PHI into regular trash
 - ✗ Leaving computer unlocked
-

Correct behavior:

- ✓ Lock screens

✓ Secure printouts

✓ Use secure disposal methods

16. Phishing & Social Engineering

One of the biggest healthcare threats today.

Phishing

Attacker sends fake email.

Example:

`Click here to reset your password.`

Employee clicks.

Attacker steals credentials.

Social Engineering

Attacker manipulates people.

Example:

Pretending to be:

- IT support
- Manager
- Vendor

to obtain sensitive information.

17. Compliance Training

Healthcare employees must regularly attend:

- HIPAA training
- Security awareness training
- Privacy training

Purpose:

Keep security awareness high.

18. 21st Century Cures Act

21st Century Cures Act

A newer law promoting:

- Transparency
 - Data sharing
 - Patient access
-

19. Information Blocking

What is Information Blocking?

When organizations intentionally prevent health information from being shared.

Example

Hospital refuses to send records to another provider.

Reason:

They don't want to lose patients.

This is information blocking.

The Cures Act discourages this behavior.

20. APIs in Healthcare

The Cures Act promotes standardized APIs.

Example

Banking App

Bank → API → Mobile App

Healthcare App

Hospital → API → Patient App

Patients can access records directly from apps.

21. Open Notes

Patients can now see:

- Doctor notes
- Visit summaries
- Clinical observations

Almost immediately.

This concept is called:

Open Notes

Benefits

- Transparency
 - Better patient engagement
 - Fewer misunderstandings
-

Quick Revision Sheet

HIPAA

Protects patient health information.

PHI

Protected Health Information.

ePHI

Electronic Protected Health Information.

Privacy Rule

Controls who can access patient data.

Security Rule

Protects electronic health data.

Minimum Necessary Rule

Only access data needed for your job.

Promoting Interoperability

Encourages active use and sharing of EHR data.

Electronic quality metrics extracted from EHRs.

Phishing

Fake messages used to steal information.

Information Blocking

Unreasonably preventing data sharing.

21st Century Cures Act

Promotes interoperability, APIs, and patient access.

For a Ruby/Python Developer

Think of Healthcare Compliance as:

Software Concept	Healthcare Equivalent
RBAC	Minimum Necessary Access
Authentication	HIPAA Security Controls
Encryption	ePHI Protection
Audit Logs	Compliance Audits
REST APIs	Interoperability APIs
Data Governance	HIPAA Compliance
Security Training	Compliance Training
API Access	Patient Data Access

Key takeaway: In healthcare IT, building the feature is only half the job. The other half is ensuring the feature is secure, auditable, compliant with HIPAA, and supports interoperability.